

4-ый этап индивидуального проекта

Основы информационной безопасности

Верниковская Е. А., НПИбд-01-23

2 мая 2025

Российский университет дружбы народов, Москва, Россия

Вводная часть

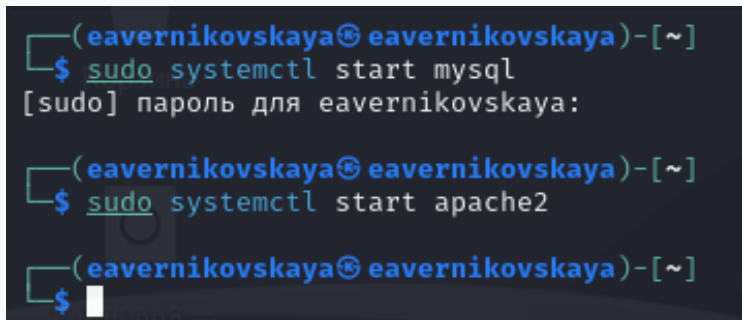
Научиться тестированию веб-приложений с помощью сканера nikto.

1. Использовать сканер nikto

Выполнение 4-ого этапа индивидуального проекта

Выполнение основных действий

Чтобы работать с nikto, надо сначала подготовить веб-приложение, которое мы будем сканировать. Это будет DVWA. Запустим mysql и apache2: *sudo systemctl start mysql* и *sudo systemctl start apache2* (рис. 1)



```
(eavernikovskaya@eavernikovskaya)~$ sudo systemctl start mysql
[sudo] пароль для eavernikovskaya:

(eavernikovskaya@eavernikovskaya)~$ sudo systemctl start apache2

(eavernikovskaya@eavernikovskaya)~$
```

Рис. 1: Запуск mysql и apache2

Выполнение основных действий

Далее введём в адресной строке браузера адрес DVWA и перейдём в режим уровня безопасности. Поставим минимальный уровень безопасности “Low” (рис. 2)

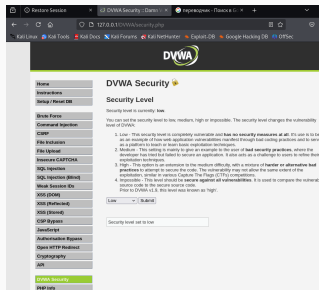
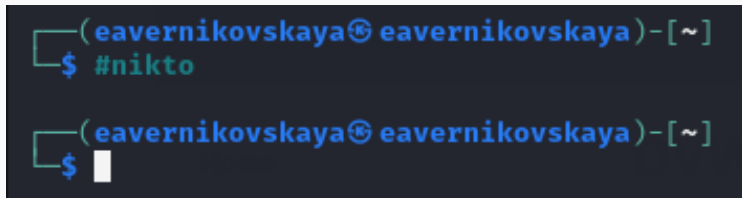


Рис. 2: Запуск DVWA

Далее запустим nikto (рис. 3)

A terminal window with a dark background. The prompt is '(eavernikovskaya@eavernikovskaya)~'. The command '#nikto' is entered and executed. The prompt is shown again with a cursor at the end.

```
(eavernikovskaya@eavernikovskaya)~  
$ #nikto  
  
(eavernikovskaya@eavernikovskaya)~  
$
```

Рис. 3: Запуск nikto

Выполнение основных действий

Проверить веб-приложение можно введя его полный URL. Просканируем веб-приложение таким образом введя команду *nikto -h http://127.0.0.1/DVWA/* (рис. 4)

```

[severnikovskaya@severnikovskaya:~]$ nikto -h http://127.0.0.1/DVWA/
- Nikto v2.5.0

+ Target IP:      127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port:    80
+ Start Time:     2025-05-02 13:42:31 (GMT+3)

+ Server: Apache/2.4.62 (Debian)
+ /DVWA/: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /DVWA/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ Root page /DVWA redirects to: login.php
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET
+ /DVWA///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /DVWA/config/: Directory indexing found.
+ /DVWA/config/: Configuration information may be available remotely.
+ /DVWA/tests/: Directory indexing found.
+ /DVWA/tests/: This might be interesting.
+ /DVWA/database/: Directory indexing found.
+ /DVWA/database/: Database directory found.
+ /DVWA/docs/: Directory indexing found.
+ /DVWA/login.php: Admin login page/section found.
+ /DVWA/.git/index: Git Index file may contain directory listing information.
+ /DVWA/.git/HEAD: Git HEAD file found. Full repo details may be present.
+ /DVWA/.git/config: Git config file found. Infos about repo details may be present.
+ /DVWA/.gitignore: .gitignore file found. It is possible to grasp the directory structure.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-includes/js/tinymce/themes/modern/Menuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/wp-content/themes/modern/Menuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /DVWA/login.cgi?cli=aa20ax27catk28/etc/hosts: Some D-Link router remote command execution.
+ /DVWA/shell.txt/etc/hosts: A backdoor was identified.
+ /DVWA/.dockerignore: .dockerignore file found. It may be possible to grasp the directory structure and learn more about the site.
+ 8874 requests: 0 error(s) and 26 item(s) reported on remote host
+ End Time:     2025-05-02 13:43:03 (GMT+3) (32 seconds)
```

Рис. 4: Сканирование веб-приложения по полному URL

Выполнение основных действий

Проверить веб-приложение можно также введя адрес хоста и адрес порта. Просканируем веб-приложение таким образом введя команду *nikto -h 127.0.0.1 -p 80* (рис. 5)

```
eavernikovskaya@eavernikovskaya:~$ nikto -h 127.0.0.1 -p 80
- Nikto v2.5.0

+ Target IP:      127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port:    80
+ Start Time:     2025-05-02 13:45:11 (GMT3)

+ Server: Apache/2.4.62 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 29cf, size: 62e677e20b79f, mtime: gzip. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ OPTIONS: Allowed HTTP Methods: POST, OPTIONS, HEAD, GET .
+ ///etc/hosts: The server install allows reading of any system file by adding an extra '/' to the URL.
+ /server-status: This reveals Apache information. Comment out appropriate line in the Apache conf file or restrict access to allowed sources. See: OSVDB-561
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/Requests/Utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /assets/mobirise/css/meta.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.
+ /login.cgi?cli=aa28aa27c18280/etc/hosts: Some D-Link router remote command execution.
+ /shellcat/etc/hosts: A backdoor was identified.
+ 8074 requests: 0 error(s) and 15 item(s) reported on remote host
+ End Time:      2025-05-02 13:45:46 (GMT3) (35 seconds)
```

Рис. 5: Сканирование веб-приложения по адресу хоста и адресу порта

Подведение итогов

В ходе выполнения 4-ого этапа индивидуального проекта мы научились использовать сканер nikto для тестирования веб-приложений.

1. Этапы реализации проекта [Электронный ресурс] URL: <https://esystem.rudn.ru/mod/page/view.php?id=1220336>
2. Обзор сканера Nikto для поиска уязвимостей в веб-серверах [Электронный ресурс] URL: <https://habr.com/ru/companies/first/articles/731696/>